SIMATS ENGINEERING

ASSESSMENT TOOL 2

Course Name: Ethical Hacking
Course Code: ITA1410

Title: Social Engineering Simulation

Submitted by: K. Sri Lasya
Register Number: 192472216

---

1. INTRODUCTION

Social engineering is a cybersecurity technique in which attackers manipulate people into revealing confidential information, performing unauthorized actions, or providing access to computer systems. Instead of depending entirely on technical vulnerabilities, social engineering exploits human behavior, trust, curiosity, fear, and urgency.

Organizations use email, web applications, domain names, servers, and cloud services to conduct their daily operations. Publicly available information about these resources can sometimes reveal details about an organization's infrastructure and employees. Attackers may collect such information during reconnaissance and use it to plan targeted attacks.

Open-Source Intelligence (OSINT) is the process of gathering and analyzing information from publicly available sources. Email addresses, domain registration details, subdomains, publicly visible technology information, and network service information can contribute to an organization's security assessment.

Phishing is another important social engineering technique. It involves sending deceptive messages that appear to originate from trusted individuals or organizations. A phishing message may encourage a recipient to open a malicious attachment, follow a suspicious link, or enter credentials on a fraudulent website.

Network scanning tools can also provide useful information about exposed services, operating systems, and application versions. When combined with information gathered through OSINT, these details can increase the risk of convincing impersonation and targeted phishing attacks.

This assessment consists of three practical activities:

1. Conducting an OSINT-based email enumeration assessment using theHarvester.

2. Conducting a controlled phishing awareness simulation using GoPhish and dummy employee accounts.
3. Examining network services using Nmap and analyzing the potential social engineering risks.

The purpose of these activities is to understand how information gathering and social engineering techniques can create security risks and how organizations can reduce those risks through technical controls, employee awareness, and security policies.

All practical activities must remain within the authorized assessment scope. The phishing simulation must use designated dummy accounts, and no real employee credentials should be collected.

2. OBJECTIVES

The major objectives of this assessment are:

1. To understand the concept of social engineering and its role in cybersecurity.
2. To use theHarvester for authorized OSINT-based information gathering.
3. To identify publicly available email addresses, subdomains, and host information where available.
4. To understand how publicly available information can support reconnaissance and targeted phishing.
5. To conduct a controlled phishing awareness simulation using GoPhish.
6. To understand delivery rate, email open rate, and click rate.
7. To use Nmap for authorized network service and operating system detection.
8. To evaluate how technical information can be misused in social engineering scenarios.
9. To recommend preventive, detective, and corrective security measures.
10. To document commands, procedures, observations, findings, and recommendations in a structured report.

---

3. QUESTION 1 – OSINT-BASED EMAIL ENUMERATION USING THEHARVESTER

3.1 Introduction

OSINT-based email enumeration is a reconnaissance activity that involves identifying publicly available email addresses associated with a particular domain. It can also involve collecting subdomains, hostnames, and associated IP address information from permitted public sources.

In this assessment, the target domain specified in the question is tesla.com.

TheHarvester is an OSINT tool available in Kali Linux that helps security analysts collect publicly accessible information from supported search engines, certificate databases, and other information sources.

The information returned depends on the selected source, tool version, source availability, and any applicable access restrictions. Therefore, the results must be recorded from the actual execution rather than assumed in advance.

The collected information can help a security analyst evaluate how much information about an organization is publicly exposed. The same information could also be misused by an attacker to prepare targeted phishing emails or impersonate departments within an organization.

3.2 Objectives

The objectives of this experiment are:

- To execute theHarvester in Kali Linux.
- To identify publicly available domain-related information.
- To collect email addresses when supported sources provide them.
- To discover publicly listed subdomains and hostnames.
- To examine associated IP addresses where returned.
- To categorize verified email addresses by likely organizational role.
- To analyze reconnaissance and social engineering risks.
- To recommend measures that reduce unnecessary information exposure.

3.3 Tools and Technologies

Kali Linux: A Linux distribution commonly used for authorized cybersecurity testing and security analysis.

theHarvester: An OSINT tool for collecting publicly available email addresses, subdomains, hosts, and related information from supported sources.

Terminal: The command-line interface used to execute the tool.

Public certificate databases: Services that expose information from publicly logged TLS certificates, which may reveal domain names and subdomains.

Text editor or report file: Used to organize findings and document the results.

3.4 Procedure and Commands

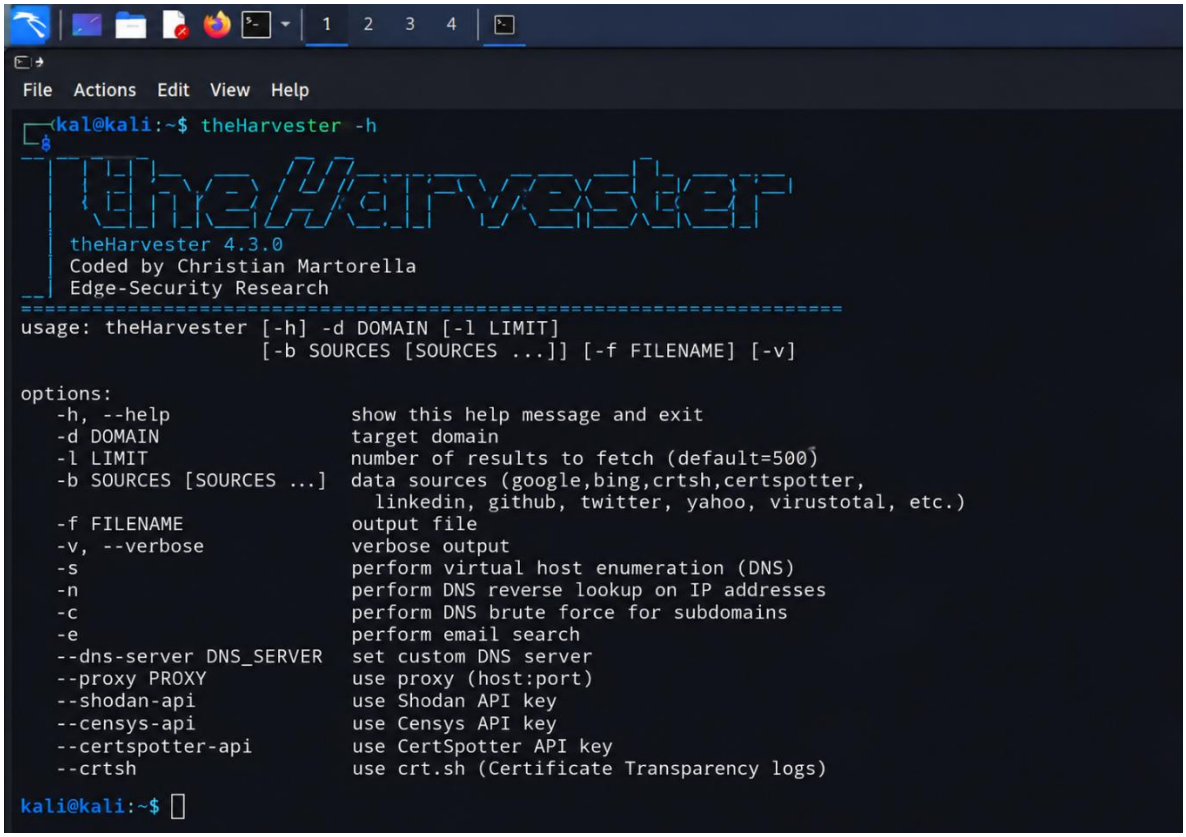
Step 1: Open Kali Linux Terminal

Open the terminal application in Kali Linux.

Step 2: Check theHarvester availability

Execute the following command:

theHarvester -h



This command displays the help information, available options, and supported data sources.

If the command is not found, check whether theHarvester is installed. On a Debian-based Kali installation, installation can be attempted using:

sudo apt update

sudo apt install theharvester

Use the installed version's documentation if package names or available options differ.

Step 3: Identify supported data sources

Run:

theHarvester -h

Review the source list displayed by the installed version. Select a passive public source that is supported by the tool.

For example, a certificate-transparency source may be used to discover publicly logged subdomains. The available source names may differ between versions.

Step 4: Conduct passive domain reconnaissance

Use the following example command if both sources are supported by your installed version:

theHarvester -d tesla.com -b crtsh,certspotter



Explanation:

- theHarvester launches the OSINT tool.
- -d tesla.com specifies the domain being assessed.
- -b selects the information sources.
- crtsh,certspotter identifies example certificate-related sources, subject to version support.

This command is intended to collect publicly accessible information. Certificate sources may provide subdomains but may not provide email addresses.

Step 5: Save the output

To save the results in a report file, execute:

theHarvester -d tesla.com -b crtsh,certspotter -f tesla_osint



The tool will attempt to save the output using the specified filename or format supported by the installed version.

If a source is unavailable or rejected, use a supported source shown by the help command and document the limitation.

Step 6: Examine the collected information

Review the output and identify the following categories wherever data is returned:

1. Publicly available email addresses.
2. Discovered subdomains.
3. Hostnames.
4. Associated IP addresses, if returned.
5. Source of the information.
6. Any errors, unavailable sources, or incomplete results.

Do not assume that an email address, hostname, or IP address exists merely because the assessment requests it.

Step 7: Organize the findings

Record the actual observations in the following tables.

Table 3.1: OSINT Assessment Summary

Information category	**Actual finding**
Target domain	tesla.com

Data sources used	Fill in actual sources
Email addresses found	Fill in actual count
Subdomains found	Fill in actual count
Hostnames found	Fill in actual count
IP addresses found	Fill in actual count, if available
Errors or limitations	Fill in actual observations

Table 3.2: Email Classification

Email address	**Likely role**	**Evidence or basis**
Enter an address returned by the tool	Support, if supported by its published role	Actual public source
Enter an address returned by the tool	Sales, if supported by its published role	Actual public source
Enter an address returned by the tool	Human Resources, if supported by its published role	Actual public source
Enter an address returned by the tool	Administration, if supported by its published role	Actual public source
Enter an address returned by the tool	Technical Team, if supported by its published role	Actual public source

If no addresses are found, record zero results and explain that the selected sources did not return publicly available email addresses. Do not invent employee identities or email addresses.

3.5 Information Collection and Classification

3.5.1 Email Addresses

Email addresses are important pieces of organizational information. Public business contact addresses may reveal the names of departments, employees, or technical contacts.

For example, an address published on an official support page may indicate a support function. However, the name of an email account alone does not prove the identity, department, or authority of the account owner.

Email classification should therefore be based on reliable public evidence rather than assumptions.

3.5.2 Subdomains

A subdomain is a subdivision of a primary domain. It can be used to separate services or applications.

Examples of common naming patterns include:

- support.example.com
- mail.example.com
- dev.example.com
- portal.example.com

These are generic examples only and are not findings about the target organization.

Subdomains can help security analysts understand the publicly visible structure of an organization's internet-facing services. They may also reveal forgotten or outdated systems that require further security review.

3.5.3 Hostnames and IP Addresses

A hostname is a human-readable name associated with a network-connected system or service. An IP address identifies a network interface or endpoint.

The information collected by an OSINT tool may contain hostnames and IP addresses, but not every source returns all these fields. DNS resolution or separate authorized checks may be needed to verify associations.

An IP address alone does not establish the physical location, ownership, operating system, or security condition of a system.

3.5.4 Role-Based Classification

The assessment asks for categorization into Support, Sales, Human Resources, Administration, and Technical Teams.

This classification can be performed using public job descriptions, official contact pages, published department information, and other legitimate sources.

If a contact's role cannot be verified, label it **Unknown** instead of making an unsupported classification.

3.6 Reconnaissance and Risk Analysis

The information collected during OSINT can help a security analyst identify unnecessary public exposure. It can also help explain how attackers might plan social engineering attacks.

3.6.1 Spear-Phishing Risk

Spear-phishing is a targeted phishing attack directed at a specific person or group.

An attacker might use publicly available organizational information to make a deceptive email appear relevant to the recipient's work. A message that appears to relate to a known department or business process may be more convincing than a generic message.

Potential consequences include unauthorized account access, exposure of confidential information, malware infection, and business disruption.

3.6.2 Credential Harvesting Risk

Credential harvesting involves deceiving a user into entering login information on an unauthorized page or disclosing credentials through another method.

Public information about an organization's email format or login services could help an attacker make an impersonation attempt appear credible.

Possible impacts include account compromise, unauthorized access to business applications, and further phishing attempts against colleagues.

3.6.3 Impersonation Risk

Impersonation occurs when an attacker pretends to be a legitimate employee, support representative, administrator, or business partner.

Public email addresses and department information may be used to create a false appearance of legitimacy. Employees may be pressured into disclosing information or approving an unauthorized request.

3.6.4 Subdomain Exposure Risk

Unnecessary public subdomains can increase the visible attack surface. An outdated application or misconfigured service may require further investigation by an authorized security team.

However, discovering a subdomain does not prove that it is vulnerable. Each finding must be verified through an approved assessment process.

3.6.5 Risk Assessment Table

Table 3.3: Potential Risks Identified Through OSINT

Information exposed	Potential risk	Recommended response
Public email addresses	Targeted phishing	Awareness training and email authentication

Department information	Impersonation	Verification procedures
Public subdomains	Increased attack surface	Asset inventory and regular review
Hostnames and IP addresses	Infrastructure mapping	Exposure review and monitoring
Outdated public records	Misleading or stale information	Review and update public records

These are potential risks associated with the information categories. They should not be reported as confirmed vulnerabilities unless the assessment actually verifies them.

3.7 Countermeasures

The following measures can reduce information leakage and social engineering risk.

1. Minimize Unnecessary Public Information

Organizations should review their websites, public documents, and contact directories to ensure that only necessary information is exposed.

2. Implement Email Authentication

SPF, DKIM, and DMARC help receiving mail systems evaluate whether messages are authorized to use a domain and whether message authentication checks pass.

A carefully configured DMARC policy can help reduce successful domain spoofing. These controls do not eliminate every phishing attack.

3. Provide Security Awareness Training

Employees should be trained to recognize suspicious links, unexpected attachments, unusual requests, and attempts to create urgency.

Training should include practical examples and a clear method for reporting suspicious messages.

4. Enforce Multi-Factor Authentication

Multi-factor authentication adds another verification factor beyond a password. Phishing-resistant authentication methods, such as appropriately configured passkeys or hardware security keys, provide stronger protection against credential phishing.

5. Maintain an Accurate Asset Inventory

Organizations should maintain a list of approved domains, subdomains, internet-facing applications, and services. Unnecessary resources should be removed or secured.

6. Monitor Public Exposure

Periodic OSINT reviews can identify newly exposed information, forgotten subdomains, or outdated public records.

7. Apply Least Privilege

Employees and service accounts should receive only the permissions necessary for their responsibilities. This can limit the impact of a compromised account.

8. Establish an Incident Reporting Process

Employees should know how to report suspicious emails and suspected account compromise. Security teams should investigate reports promptly.

3.8 Result

The OSINT assessment procedure using theHarvester is designed to identify publicly available email addresses, subdomains, hostnames, and related information associated with tesla.com.

The actual findings depend on the selected sources and the output obtained during execution. The collected information can be used to evaluate public exposure and potential reconnaissance risks.

The activity demonstrates the importance of limiting unnecessary public information, securing email systems, maintaining an asset inventory, and improving employee awareness.

Practical evidence: Insert the actual terminal screenshots and the output summary obtained during execution.

---

4. QUESTION 2 – PHISHING AWARENESS SIMULATION USING GOPHISH

4.1 Introduction

Phishing is a social engineering technique in which an attacker attempts to deceive recipients into taking an unsafe action. These actions may include clicking a suspicious link, opening an unexpected attachment, disclosing confidential information, or visiting a fraudulent login page.

Organizations use phishing awareness simulations to evaluate employee awareness and identify areas where additional training is needed.

GoPhish is an open-source phishing simulation framework that provides a web interface for creating email templates, managing recipient groups, configuring campaigns, and reviewing recorded interactions.

In this assessment, GoPhish is used to conduct a controlled simulation with dummy employee accounts provided by the laboratory. The purpose is to measure awareness and recommend improvements, not to collect real credentials.

4.2 Objectives

The objectives are:

1. To understand the purpose of phishing awareness simulations.
2. To create a controlled email template.
3. To configure a recipient group containing authorized dummy accounts.
4. To configure the campaign through the GoPhish interface.
5. To monitor email delivery, opens, and clicks.
6. To calculate campaign performance metrics.
7. To identify weaknesses in phishing awareness.
8. To recommend appropriate preventive and corrective measures.

4.3 Tools and Technologies

GoPhish: Used to create and manage authorized phishing awareness simulations.

Kali Linux: The environment used to run the GoPhish application, if installed there.

Web browser: Used to access the GoPhish administration interface.

Dummy employee accounts: Test accounts provided by the laboratory for the campaign.

Email delivery service or laboratory mail server: Used to deliver simulation emails according to the authorized lab configuration.

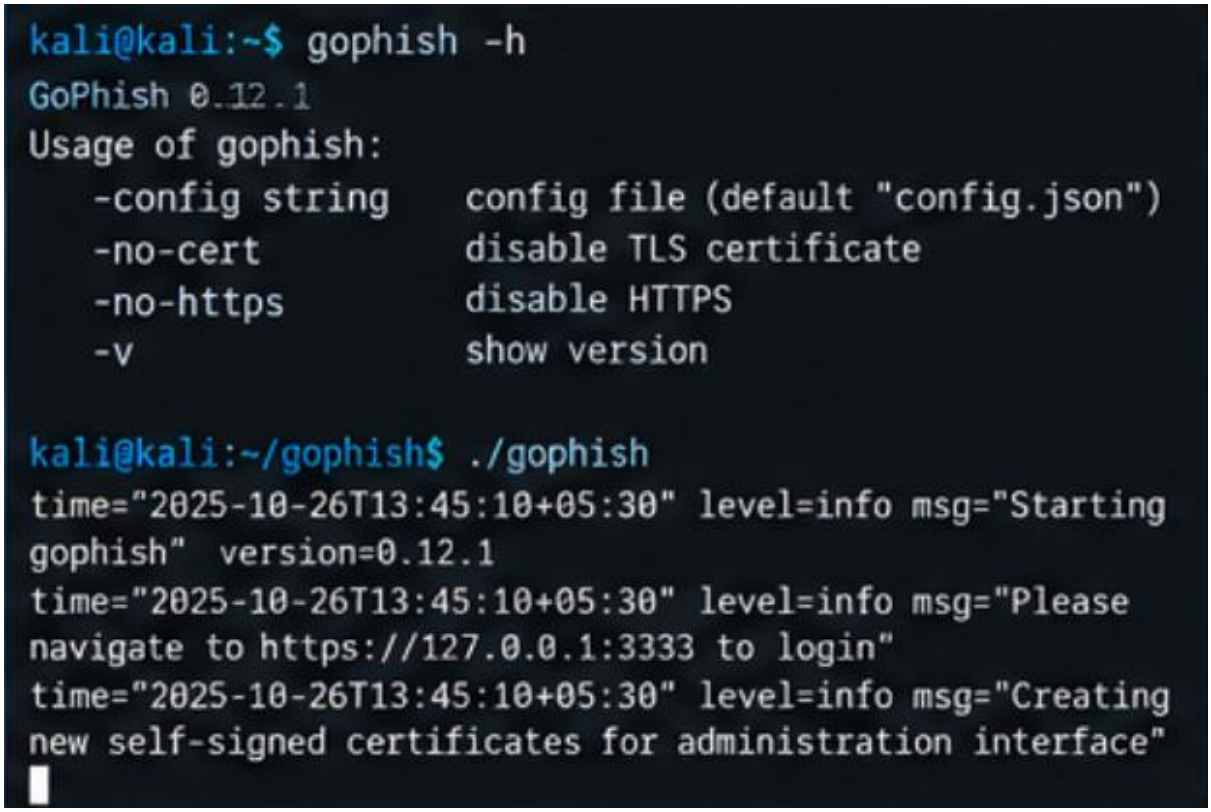
Spreadsheet or report document: Used to record the campaign results and calculate the required percentages.

4.4 Campaign Setup and Procedure

Step 1: Verify GoPhish availability

Open the Kali Linux terminal and run:

gophish -h



If the command is unavailable, locate the GoPhish application or the extracted installation folder.

If GoPhish has already been started, check the running processes:

ps aux | grep '[g]ophish'

This command helps determine whether a GoPhish process is running.

If your laboratory provides a GoPhish executable, navigate to its directory and start it using the provided instructions. For an extracted Linux binary named gophish, the commands may be:

cd ~/Downloads

ls

Navigate into the actual folder shown by ls. If the executable is present and supplied for your lab, run:

chmod +x gophish

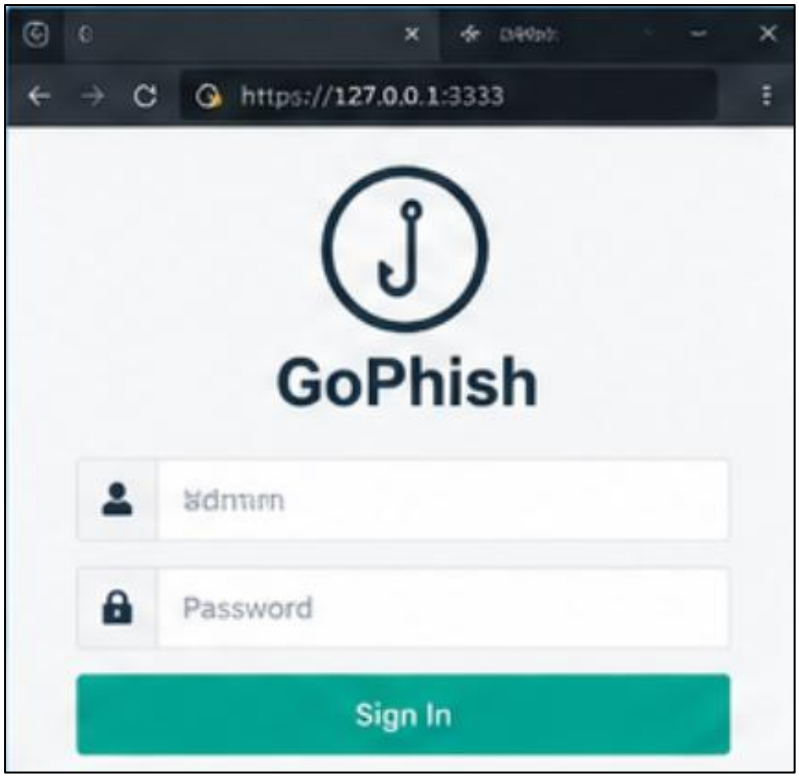
./gophish

The exact folder and startup procedure depend on the installation.

Step 2: Open the local administration interface

The GoPhish interface commonly uses a local address such as:

https://127.0.0.1:3333



Open the address displayed by your GoPhish installation in Firefox.

A browser may show a certificate warning if the local administration interface uses a self-signed certificate. Proceed only after confirming that the address is the local interface for the GoPhish instance you intentionally started.

Use the administrator credentials supplied by the laboratory or established during installation.

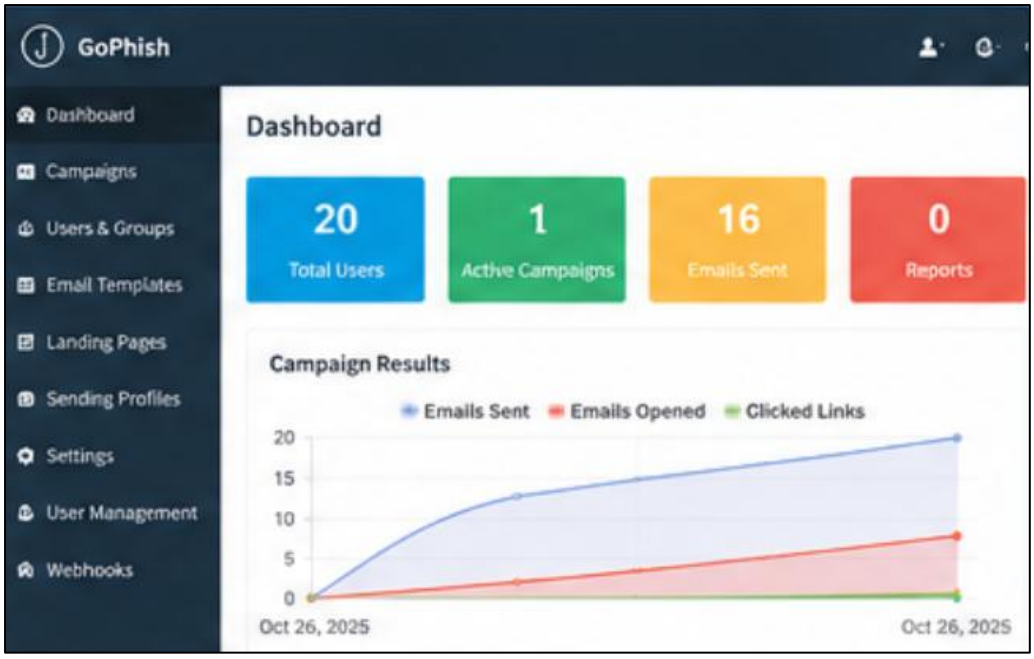
Step 3: Create an email template

Navigate to the email template section in GoPhish.

Create a clearly controlled awareness message for the dummy accounts. The message should be approved for the exercise and should not request real passwords or other sensitive personal information.

Example template:

Subject: Security Awareness Exercise – Account Safety Reminder



Email body:

Dear Employee,

This is an authorized security awareness exercise conducted within the laboratory environment. Please review the message carefully and follow your organization's standard procedures for verifying unexpected security notifications.

Never enter credentials into an unfamiliar website, and report suspicious emails through the approved reporting channel.

Regards,
Security Awareness Team

For a simulation that measures clicks, use the approved tracking link configured through the laboratory's GoPhish campaign. Do not direct participants to a real credential collection page.

Step 4: Create the recipient group

Open the Users & Groups section and create a group containing the dummy employee accounts provided by the laboratory.

Record the total number of authorized recipients.

Table 4.1: Recipient Group Details

Parameter	**Actual value**

Group name	Enter the lab group name
Number of recipients	Enter actual count
Account type	Dummy laboratory accounts
Authorization	Approved laboratory exercise

Do not include real employee accounts or external recipients unless explicitly authorized.

Step 5: Configure the sending profile

Create or select the sending profile supplied for the laboratory. Configure the permitted mail server and sender details according to the lab instructions.

Confirm that the mail server is authorized for this exercise and that the sender configuration is appropriate for the controlled environment.

Step 6: Configure the campaign

Create a new campaign and select:

- The approved email template.
- The dummy recipient group.
- The laboratory sending profile.
- The approved tracking or landing page, if required.
- The campaign schedule specified by the laboratory.

Review all settings before launching the campaign.

Step 7: Launch the campaign

Launch the campaign only against the authorized dummy accounts.

Monitor the campaign dashboard to identify whether messages were delivered, opened, or clicked. The recorded results depend on the mail server, recipient configuration, client behavior, and tracking settings.

Step 8: Collect the results

After the simulation has completed, record the actual values shown by GoPhish.

Table 4.2: Campaign Results

Metric	Actual result
Total recipients	Enter actual count
Emails sent	Enter actual count
Emails delivered	Enter actual count, if available
Emails opened	Enter actual count
Links clicked	Enter actual count
Credentials submitted	Not collected; unless a specifically approved safe test indicator is used

Do not insert estimated percentages as if they were measured results.

4.5 Performance Metrics

The three metrics specifically requested in the assessment are delivery rate, email open rate, and click rate.

4.5.1 Delivery Rate

Delivery rate measures the proportion of sent messages that were successfully delivered according to the campaign's available delivery data.

1. Delivery Rate

$$\text{Delivery Rate} = \frac{\text{Emails Delivered}}{\text{Emails Sent}} \times 100$$

Example: If 18 out of 20 sent emails were delivered,

$$\text{Delivery Rate} = \frac{18}{20} \times 100 = 90\%$$

2. Email Open Rate

$$\text{Email Open Rate} = \frac{\text{Emails Opened}}{\text{Emails Delivered}} \times 100$$

Example: If 12 out of 18 delivered emails were opened,

$$\text{Email Open Rate} = \frac{12}{18} \times 100 = 66.67\%$$

3. Click Rate

$$\text{Click Rate} = \frac{\text{Emails Clicked}}{\text{Emails Delivered}} \times 100$$

Example: If 4 out of 18 delivered emails received clicks,

$$\text{Click Rate} = \frac{4}{18} \times 100 = 22.22\%$$

Some organizations instead calculate clicks divided by sent emails. The report should state the denominator used and remain consistent.

4.5.4 Results Interpretation



The actual campaign results should be interpreted according to the following principles:

- A low delivery rate may indicate mail server, address, filtering, or configuration issues.
- A high open rate may indicate that the email attracted attention, but it does not establish that the recipient read or trusted it.
- A high click rate may indicate that the message persuaded more recipients to follow its link.
- A low click rate may suggest better awareness, but the conclusion should be supported by the campaign context.
- A reported click may have been generated by an automated security scanner rather than a person.

Table 4.3: Performance Interpretation

Metric	**What it helps evaluate**
Delivery rate	Email delivery and campaign configuration
Open rate	Recorded email interaction
Click rate	Recorded interaction with the simulation link
Report rate, if available	Employee willingness to identify and report suspicious messages

4.6 Risk Analysis

4.6.1 Human-Related Vulnerabilities

Employees may trust messages that appear to come from a familiar department or authority figure. They may also react to urgency, fear, or unexpected account warnings without checking the sender or link.

4.6.2 Credential Theft

A real phishing attack may direct a user to a fraudulent login page. Entered credentials can then be misused to access business systems.

This assessment should measure awareness without collecting real passwords.

4.6.3 Malware Exposure

Some phishing campaigns use malicious attachments or links that lead to harmful downloads. Opening such content can result in malware infection or unauthorized system access.

The laboratory exercise should not use real malware or unsafe attachments.

4.6.4 Business Impact

A successful phishing attack may lead to account compromise, data exposure, financial loss, operational disruption, or reputational damage.

The severity depends on the affected account's privileges, the systems it can access, and the organization's incident response capability.

4.7 Recommendations to Improve Awareness

1. Conduct Regular Awareness Training

Employees should learn to identify suspicious senders, misleading links, unexpected attachments, and unusual requests.

2. Implement Email Filtering

Email filtering should detect and block suspicious messages, known malicious links, and unsafe attachments.

3. Configure SPF, DKIM, and DMARC

These email authentication mechanisms help receiving systems identify unauthorized use of a domain and reduce certain types of spoofing.

4. Enforce Multi-Factor Authentication

MFA reduces the risk of unauthorized account access when a password is compromised. Phishing-resistant authentication should be preferred where feasible.

5. Establish an Email Reporting Process

Employees should have a simple way to report suspicious messages to the IT or security team.

6. Review Simulation Results

Training should be focused on the weaknesses identified by actual campaign data. Results should be used to improve awareness, not to shame individual employees.

7. Apply Least Privilege

Limiting unnecessary account permissions can reduce the impact of a compromised account.

8. Monitor Suspicious Sign-In Activity

Security teams should monitor unusual login attempts, unexpected locations, and suspicious account activity.

9. Establish Incident Response Procedures

If an employee interacts with a real phishing message, the organization should have clear procedures for reporting, account protection, investigation, and recovery.

4.8 Result

A controlled phishing awareness campaign can be configured through GoPhish using dummy laboratory accounts. The campaign dashboard can be used to examine delivery, open, and click metrics.

The actual percentages must be calculated from the recorded campaign results. These metrics can help identify awareness gaps and guide improvements in employee training, email security, authentication, and incident response.

Practical evidence: Insert screenshots of the template, dummy recipient group, campaign configuration, results dashboard, and recorded metrics.

---

5. QUESTION 3 – NMAP AGGRESSIVE SCAN AND SOCIAL ENGINEERING RISK

5.1 Introduction

Network scanning is a cybersecurity technique used to identify active hosts, open ports, and exposed network services. It can help authorized security analysts understand which services are accessible and whether unnecessary exposure exists.

Nmap, also known as Network Mapper, is a widely used network discovery and security auditing tool.

The -A option enables several advanced detection features, including operating system detection, service/version detection, default script scanning, and traceroute. The information obtained depends on network conditions, target configuration, and the permissions available to the scanning process.

In this assessment, the designated target is scanme.nmap.org, a host provided by the Nmap project for testing Nmap. The assessment should respect the target's published usage restrictions and should not include exploit attempts or denial-of-service testing.

The purpose of the experiment is to understand how technical information might support social engineering attempts against an IT support team and how organizations can reduce the associated risk.

5.2 Objectives

1. To understand the purpose of network scanning.
2. To execute an Nmap aggressive scan against the designated training target.
3. To identify open ports and detected services.
4. To examine operating system detection information when available.
5. To understand service version detection.
6. To analyze how technical details could be misused in impersonation.
7. To recommend security measures for IT support and network administration.

5.3 Tools and Technologies

Nmap: A network scanning tool used to discover hosts, open ports, and service information.

Kali Linux: The environment used to execute the scan.

Terminal: Used to enter commands and observe results.

Text file: Used to preserve the scan output for the report.

5.4 Commands and Procedure

Step 1: Check Nmap installation

Execute:

nmap –version

```
kali@kali:~$ nmap --version
Nmap version 7.94SVN ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.4 openssl-3.0.11
zlib-1.2.13 libpcap-1.10.4 nmap-libssh2-1.11.0
libpcre-8.45 nmap-libdnet-1.12 ipv6
Compiled without:
Available nsock engines: epoll poll select
```

This displays the installed Nmap version and associated build information.

Step 2: Execute the aggressive scan

Run:

nmap -A scanme.nmap.org

```
kali@kali:~$ nmap -A scanme.nmap.org
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-26 14:10 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.12s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE    VERSION
22/tcp    open  ssh        OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http       Apache httpd 2.4.7 ((Ubuntu))
9929/tcp  open  nping-echo  Nping echo
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 27.85 seconds
```

Explanation:

- nmap starts the network scanning tool.
- -A enables OS detection, service/version detection, default scripts, and traceroute.
- scanme.nmap.org identifies the designated training target.

The results must be taken from the actual scan. Do not assume a specific set of open ports or operating system details.

Step 3: Save the scan output

Execute:

nmap -A scanme.nmap.org -oN nmap_report.txt

```
kali@kali:~$ nmap -A scanme.nmap.org -oN nmap_report.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-26 14:12 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.12s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT     STATE  SERVICE    VERSION
22/tcp   open   ssh        OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
80/tcp   open   http       Apache httpd 2.4.7 ((Ubuntu))
9929/tcp open   nping-echo  Nping echo
Nmap done: 1 IP address (1 host up) scanned in 27.64 seconds
kali@kali:~$ ls
nmap_report.txt
```

The -oN option saves the output in normal text format to nmap_report.txt.

Step 4: Review the output

Examine the output for:

- Target identification.
- Host availability.
- Open ports.
- Service names.
- Detected service versions.
- Operating system detection results, if available.
- Scan completion information.
- Limitations or detection uncertainties.

Step 5: Record the actual observations

Table 5.1: Nmap Scan Summary

Parameter	**Actual observation**
Target	scanme.nmap.org
Scan command	nmap -A scanme.nmap.org

Host status	Enter actual result
Open ports	Enter actual result
Detected services	Enter actual result
Service versions	Enter actual result
OS detection	Enter actual result, if available
Scan limitations	Enter actual observations

The target's results may change over time. Use the current output instead of copying results from another report.

5.5 Analysis of Scan Information

5.5.1 Open Ports

A port is a logical communication endpoint used by network applications. An open port usually indicates that a service is accepting connections through that port.

Open ports are not automatically vulnerabilities. Their risk depends on the service, configuration, exposure, authentication, and business requirement.

Security analysts should verify whether each exposed service is necessary and appropriately protected.

5.5.2 Service Identification

Service detection attempts to identify the application or protocol associated with an open port.

This information can help administrators understand which applications are accessible and whether they require configuration changes, patching, or restricted access.

5.5.3 Version Detection

Version detection attempts to identify the software version running on a service.

Older versions may require further review against reliable vendor advisories. However, a detected version alone does not prove that the service is vulnerable. Backported security fixes, customized builds, and inaccurate detection can affect interpretation.

5.5.4 Operating System Detection

Nmap may infer the target's operating system by examining network responses.

The result may be uncertain or unavailable when responses are filtered, network devices alter traffic, or insufficient evidence is available.

An operating system result should therefore be reported with the confidence indicated by the actual scan.

5.5.5 Risk Assessment

Table 5.2: Technical Information and Potential Risks

Information	Potential security concern	Defensive response
Open ports	Unnecessary network exposure	Restrict access and close unused ports
Service names	Reveals available functionality	Maintain a service inventory
Service versions	May reveal outdated software	Verify patches and vendor advisories
OS detection	Reveals possible platform information	Limit unnecessary exposure and maintain updates
Host availability	Helps map reachable assets	Monitor network access and maintain asset records

5.6 Social Engineering Attack Scenario

5.6.1 Attack Overview

Technical information can help an attacker make an impersonation attempt sound more convincing. An attacker might pretend to be an external security consultant or an internal technical support employee and refer to a service or system in a deceptive message.

The attack scenario below is conceptual. It explains potential risks without providing instructions for targeting real IT support employees.

5.6.2 Information Gathering

An attacker may combine publicly available organizational information with general knowledge about network services.

This can create the appearance of familiarity with the organization's technical environment. However, a scan of a public training host does not reveal the internal systems of a separate organization.

5.6.3 Impersonation

An attacker may pretend to represent a trusted technical department and claim that an urgent security issue requires immediate action.

The attacker may attempt to convince an employee to disclose sensitive information, approve an unauthorized request, or bypass an established procedure.

5.6.4 Possible Impact

If an employee accepts the impersonation, potential consequences include:

- Disclosure of confidential information.
- Unauthorized account access.
- Exposure of internal procedures.
- Unauthorized system changes.
- Loss of business data.
- Operational disruption.

The presence of a social engineering risk does not mean that a successful attack has occurred. The report should distinguish between a hypothetical attack scenario and an observed security incident.

5.7 Defensive Recommendations

1. Restrict Unnecessary Network Exposure

Firewalls and access control rules should limit access to services according to business requirements.

2. Maintain Current Software

Administrators should apply security updates and verify software versions against official vendor guidance.

3. Enforce Identity Verification

IT support staff should verify the identity and authorization of people requesting sensitive actions.

4. Establish Change Management

System configuration changes should follow approved change management procedures rather than informal requests.

5. Use Multi-Factor Authentication

MFA adds a layer of protection against account compromise. Phishing-resistant authentication should be considered for sensitive administrative access.

6. Monitor Network and Authentication Logs

Security teams should review unusual connections, failed authentication attempts, and unexpected access patterns.

7. Train IT Support Employees

Support personnel should learn to recognize impersonation attempts, urgent fraudulent requests, and attempts to bypass established procedures.

8. Apply Least Privilege

Administrative access should be limited to authorized personnel and restricted to the tasks required by their responsibilities.

9. Maintain an Asset Inventory

An accurate inventory helps administrators identify exposed services, assign ownership, and prioritize remediation.

10. Establish Incident Response Procedures

Suspicious requests and suspected account compromise should be reported, investigated, and addressed through documented procedures.

5.8 Result

The Nmap aggressive scan demonstrates how network scanning can identify exposed ports, service information, and possible operating system details.

The results help explain why organizations should reduce unnecessary exposure, patch systems, monitor network activity, and enforce strong identity verification procedures.

The social engineering analysis demonstrates that technical information may contribute to convincing impersonation attempts, but the training target's scan results should not be presented as evidence about another organization's internal infrastructure.

Practical evidence: Insert the actual terminal output and the saved scan summary.

---

6. OVERALL FINDINGS AND CONCLUSION

6.1 Overall Findings

The assessment covers three important aspects of cybersecurity: public information gathering, phishing awareness, and network reconnaissance.

TheHarvester demonstrates how publicly available sources can reveal information about domains, email addresses, and subdomains. Such information can support legitimate security assessments but may also increase exposure to targeted social engineering.

GoPhish demonstrates how controlled phishing simulations can help organizations understand employee interaction with suspicious messages. Delivery, open, and click metrics provide useful information when interpreted carefully and with an understanding of tracking limitations.

Nmap demonstrates how network scanning can identify open ports, services, and possible operating system details. These observations can help administrators review exposed services and prioritize security improvements.

The combined findings show that cybersecurity requires both technical protection and employee awareness. No single tool can prevent all social engineering attacks.

6.2 Preventive, Detective, and Corrective Controls

Preventive controls reduce the likelihood of an incident. Examples include email authentication, MFA, security awareness training, least privilege, and restricting unnecessary network access.

Detective controls help identify suspicious activity. Examples include email security monitoring, authentication logs, network monitoring, and incident reporting.

Corrective controls help contain and recover from incidents. Examples include account recovery, credential resets, system patching, investigation, and remediation of misconfigured services.

An effective security program combines all three categories.

6.3 Conclusion

This assessment provides practical understanding of social engineering risks and the importance of authorized cybersecurity testing.

TheHarvester helps demonstrate how OSINT can be used to identify publicly available information. GoPhish helps evaluate awareness through a controlled phishing simulation. Nmap provides visibility into exposed network services and supports the discussion of network security risks.

The assessment also highlights the need to verify identities, secure email systems, maintain current software, restrict unnecessary network exposure, and train employees to recognize suspicious communications.

By applying preventive, detective, and corrective measures, organizations can reduce information leakage and improve their resilience against phishing, impersonation, and other social engineering attacks.

The final report should contain actual observations from the laboratory, accurately calculated metrics, relevant screenshots, and recommendations based on the results.

---

7. REFERENCES

1. TheHarvester project documentation and official repository. GitHub: https://github.com/laramies/theHarvester
2. GoPhish official project documentation and repository. GitHub: https://github.com/gophish/gophish
3. Nmap Reference Guide: https://nmap.org/book/man.html
4. Nmap scan testing information: https://nmap.org/book/legal-issues.html
5. National Institute of Standards and Technology (NIST), Cybersecurity Framework: https://www.nist.gov/cyberframework
6. Cybersecurity and Infrastructure Security Agency (CISA), Secure Our World: https://www.cisa.gov/secure-our-world
7. Internet Engineering Task Force (IETF), Sender Policy Framework (SPF), RFC 7208: https://www.rfc-editor.org/rfc/rfc7208
8. Internet Engineering Task Force (IETF), DomainKeys Identified Mail (DKIM), RFC 6376: https://www.rfc-editor.org/rfc/rfc6376
9. Internet Engineering Task Force (IETF), Domain-based Message Authentication, Reporting, and Conformance (DMARC), RFC 7489: https://www.rfc-editor.org/rfc/rfc7489

---

8. CODE OF CONDUCT

I, K. Sri Lasya,
Register Number: 192472216,
certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: K. Sri Lasya